Защищенные информационные системы

Павел Пархомец
Заместитель руководителя отдела ИБ RWB (Wildberries&Russ)

Лекция 3
2025

Этапы проникновения в сеть

1) Первичный доступ
2) Закрепление
3) Повышение привилегий
4) Дальнейшее проникновение в инфраструктуру

Сканирования

1) сетевые
2) сканирования веб приложений

Сетевые сканирования

1) host discovery
2) port scan

Сканирования портов

1) TCP-сканирование подключением
2) TCP-сканирование сообщениями SYN
3) UDP-сканирование
4) ...

Инструменты для сетевого сканирования

1) nmap
2) masscan
3) rustscan
4) naabu
5) ...

Nmap

Nmap - Это инструмент командной строки Linux с открытым исходным кодом, который используется для сканирования IP-адресов и портов в сети и обнаружения установленных приложений

Почему Nmap

- распознает устройства (серверы, маршрутизаторы и тд)
- распознает службы
- распознает операционную систему и ее версию
- позволяет сканировать уязвимости
- стабильный

Nmap базовые режимы сканирования

Ping scan - Сканирует список устройств, подключенных и запущенных в данной подсети.

```
nmap -sp 192.168.1.1/24
```

Nmap базовые режимы сканирования

Ping scan - Сканирует список устройств, подключенных и запущенных в данной подсети.

Scan a single host - Сканирует один хост на наличие 1000 хорошо известных портов. Эти порты используются популярными сервисами, такими как SQL, SNTP, apache и другими.

```
nmap scanme.nmap.org
```

Nmap базовые режимы сканирования

```
admin@ip-172-26-0-73:~$ nmap scanme.nmap.org

Starting Nmap 7.40 ( https://nmap.org ) at 2020-07-22 02:48 UTC
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.078s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed ports
PORT      STATE    SERVICE
22/tcp    open     ssh
25/tcp    filtered smtp
80/tcp    open     http
9929/tcp  open     nping-echo
31337/tcp open     Elite

Nmap done: 1 IP address (1 host up) scanned in 2.40 seconds
admin@ip-172-26-0-73:~$
```

Nmap Stealth scan

SYN Scan - Скрытое сканирование выполняется путем отправки SYN-пакета и анализа ответа. Если получен SYN/ACK, это означает, что порт открыт, и вы можете открыть TCP-соединение.

Для сканирования используется опция -sS

```
nmap -sS scanme.nmap.org
```

Nmap Сканирование версий

```
admin@ip-172-26-0-73:~$ nmap -sV scanme.nmap.org

Starting Nmap 7.40 ( https://nmap.org ) at 2020-07-22 03:00 UTC
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.077s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed ports
PORT      STATE    SERVICE    VERSION
22/tcp    open     ssh        OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
25/tcp    filtered smtp
80/tcp    open     http       Apache httpd 2.4.7 ((Ubuntu))
9929/tcp  open     nping-echo Nping echo
31337/tcp open     tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.79 seconds
admin@ip-172-26-0-73:~$
```

Nmap Получение версии OS

```
Starting Nmap 7.40 ( https://nmap.org ) at 2020-07-22 04:39 UTC
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.075s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed ports
PORT      STATE    SERVICE
22/tcp    open     ssh
25/tcp    filtered smtp
80/tcp    open     http
9929/tcp  open     nping-echo
31337/tcp open     Elite
Aggressive OS guesses: Linux 2.6.32 (93%), Linux 2.6.32 or 3.10 (93%), Linux 4.4 (92%), Linux 2.6.32 - 2.6.35 (91%), Linux 2.6.32 - 2.6.
39 (91%), Linux 2.6.32 - 3.0 (90%), Linux 4.0 (89%), Linux 3.11 - 4.1 (89%), Linux 3.2 - 3.8 (89%), Linux 2.6.18 (89%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 15 hops
```

Nmap агрессивный режим

Nmap имеет агрессивный режим, который включает обнаружение операционной системы, определение версии, сканирование сценариев.

```
nmap -A scanme.nmap.org
```

Nmap агрессивный режим

```
Starting Nmap 7.40 ( https://nmap.org ) at 2020-07-22 08:02 UTC
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.075s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed ports
PORT      STATE    SERVICE    VERSION
22/tcp    open     ssh        OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|_  256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
25/tcp    filtered smtp
80/tcp    open     http       Apache httpd 2.4.7 ((Ubuntu))
|_http-server-header: Apache/2.4.7 (Ubuntu)
|_http-title: Go ahead and ScanMe!
9929/tcp  open     nping-echo Nping echo
31337/tcp open     tcpwrapped
Aggressive OS guesses: Linux 2.6.32 (93%), Linux 4.4 (93%), Linux 2.6.32 or 3.10 (92%), Linux 2.6.32 - 2.6.35 (91%), Linux 2.6.32 - 2.6.
39 (91%), Linux 4.0 (90%), Linux 3.11 - 4.1 (89%), Linux 3.2 - 3.8 (89%), Linux 2.6.18 (89%), Linux 2.6.32 - 3.0 (89%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 15 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 1723/tcp)
HOP RTT      ADDRESS
1   ... 5
6   0.97 ms  100.65.14.49
7   1.34 ms  52.93.29.57
8   1.96 ms  100.100.2.6
9   1.14 ms  ash-b1-link.telia.net (62.115.11.182)
10  1.92 ms  rest-bb1-link.telia.net (80.91.248.156)
11  7.98 ms  nyk-bb3-link.telia.net (62.115.141.245)
```

Nmap сканирование нескольких хостов

> nmap 192.164.1.1 192.164.0.2 192.164.0.2

> nmap 192.164.1.*

> nmap 192.164.0.1,2,3,4

> nmap 192.164.0.0–255

Nmap сканирование портов

```
> nmap -p 973 192.164.0.1

> nmap -p T:7777, 973 192.164.0.1

> nmap -p 76–973 192.164.0.1

> nmap --top-ports 10 scanme.nmap.org
```

Nmap хостов из файла

```
> nmap -iL /input_ips.txt
```

Nmap вывод результата

Подобный вывод:

> nmap -v scanme.nmap.org

```
Starting Nmap 7.40 ( https://nmap.org ) at 2020-07-22 08:10 UTC
Initiating Ping Scan at 08:10
Scanning scanme.nmap.org (45.33.32.156) [4 ports]
Completed Ping Scan at 08:10, 0.20s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 08:10
Completed Parallel DNS resolution of 1 host. at 08:10, 0.05s elapsed
Initiating SYN Stealth Scan at 08:10
Scanning scanme.nmap.org (45.33.32.156) [1000 ports]
Discovered open port 22/tcp on 45.33.32.156
Discovered open port 80/tcp on 45.33.32.156
Increasing send delay for 45.33.32.156 from 0 to 5 due to 13 out of 41 dropped probes since last increase.
Increasing send delay for 45.33.32.156 from 5 to 10 due to 11 out of 29 dropped probes since last increase.
Increasing send delay for 45.33.32.156 from 10 to 20 due to 17 out of 56 dropped probes since last increase.
Increasing send delay for 45.33.32.156 from 20 to 40 due to 11 out of 28 dropped probes since last increase.
Increasing send delay for 45.33.32.156 from 40 to 80 due to max_successful_tryno increase to 4
Increasing send delay for 45.33.32.156 from 80 to 160 due to 11 out of 27 dropped probes since last increase.
Increasing send delay for 45.33.32.156 from 160 to 320 due to 11 out of 22 dropped probes since last increase.
SYN Stealth Scan Timing: About 16.13% done; ETC: 08:13 (0:02:41 remaining)
SYN Stealth Scan Timing: About 25.53% done; ETC: 08:14 (0:02:58 remaining)
Discovered open port 31337/tcp on 45.33.32.156
SYN Stealth Scan Timing: About 39.62% done; ETC: 08:15 (0:02:42 remaining)
SYN Stealth Scan Timing: About 48.93% done; ETC: 08:15 (0:02:22 remaining)
SYN Stealth Scan Timing: About 58.32% done; ETC: 08:15 (0:01:59 remaining)
SYN Stealth Scan Timing: About 67.72% done; ETC: 08:15 (0:01:33 remaining)
Discovered open port 9929/tcp on 45.33.32.156
```

Nmap вывод результата

Нормальный вывод:

> nmap -oN output.txt scanme.nmap.org

```
# Nmap 7.40 scan initiated Wed Jul 22 08:23:57 2020 as: nmap -oN output.txt --top-ports 10 scanme.nmap.org
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.073s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
PORT     STATE    SERVICE
21/tcp   closed   ftp
22/tcp   open     ssh
23/tcp   closed   telnet
25/tcp   filtered smtp
80/tcp   open     http
110/tcp  closed   pop3
139/tcp  closed   netbios-ssn
443/tcp  closed   https
445/tcp  closed   microsoft-ds
3389/tcp closed   ms-wbt-server
```

Nmap вывод результата

XML вывод:

> nmap -oX output.xml scanme.nmap.org

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE nmaprun>
<?xml-stylesheet href="file:///usr/bin/../share/nmap/nmap.xsl" type="text/xsl"?>
<!-- Nmap 7.40 scan initiated Wed Jul 22 08:17:51 2020 as: nmap -oX scanme.nmap.org -&#45;top-ports 10 -->
<nmaprun scanner="nmap" args="nmap -oX scanme.nmap.org -&#45;top-ports 10" start="1595405871" startstr="Wed Jul 22 08:17:51 2020" versio
n="7.40" xmloutputversion="1.04">
<scaninfo type="syn" protocol="tcp" numservices="10" services="21-23,25,80,110,139,443,445,3389"/>
<verbose level="0"/>
<debugging level="0"/>
<runstats><finished time="1595405871" timestr="Wed Jul 22 08:17:51 2020" elapsed="0.03" summary="Nmap done at Wed Jul 22 08:17:51 2020;
0 IP addresses (0 hosts up) scanned in 0.03 seconds" exit="success"/><hosts up="0" down="0" total="0"/>
</runstats>
</nmaprun>
```

Nmap вывод результата

```
➜  ~ cat output.xml
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE nmaprun>
<?xml-stylesheet href="file:///opt/homebrew/bin/../share/nmap/nmap.xsl" type="text/xsl"?>
<!-- Nmap 7.94 scan initiated Mon Feb 12 23:04:38 2024 as: nmap -oX output.xml scanme.nmap.org -->
<nmaprun scanner="nmap" args="nmap -oX output.xml scanme.nmap.org" start="1707768278" startstr="Mon Feb 12 23:04:38 2024" version="7.94" xmloutputversion="1.05">
<scaninfo type="connect" protocol="tcp" numservices="1000" services="1,3-4,6-7,9,13,17,19-26,30,32-33,37,42-43,49,53,70,79-85,88-90,99-100,106,109-111,113,119,125,135,139,143-144,146,161,163,179,199,211-212,222,254-256,259,264,280,301,306,311,340,366,389,406-407,416-417,425,427,443-445,458,464-465,481,497,500,512-515,524,541,543-545,548,554-555,563,587,593,616-617,625,631,636,646,648,666-668,683,687,691,700,705,711,714,720,722,726,749,765,777,783,787,800-801,808,843,873,880,888,898,900-903,911-912,981,987,990,992-993,995,999-1002,1007,1009-1011,1021-1100,1102,1104-1108,1110-1114,1117,1119,1121-1124,1126,1130-1132,1137-1138,1141,1145,1147-1149,1151-1152,1154,1163-1166,1169,1174-1175,1183,1185-1187,1192,1198-1199,1201,1213,1216-1218,1233-1234,1236,1244,1247-1248,1259,1271-1272,1277,1287,1296,1300-1301,1309-1311,1322,1328,1334,1352,1417,1433-1434,1443,1455,1461,1494,1500-1501,1503,1521,1524,1533,1556,1580,1583,1594,1600,1641,1658,1666,1687-1688,1700,1717-1721,1723,1755,1761,1782-1783,1801,1805,1812,1839-1840,1862-1864,1875,1900,1914,1935,1947,1971-1972,1974,1984,1998-2010,2013,2020-2022,2030,2033-2035,2038,2040-2043,2045-2049,2065,2068,2099-2100,2103,2105-2107,2111,2119,2121,2126,2135,2144,2160-2161,2170,2179,2190-2191,2196,2200,2222,2251,2260,2288,2301,2323,2366,2381-2383,2393-2394,2399,2401,2492,2500,2522,2525,2557,2601-2602,2604-2605,2607-2608,2638,2701-2702,2710,2717-2718,2725,2800,2809,2811,2869,2875,2909-2910,2920,2967-2968,2998,3000-3001,3003,3005-3007,3011,3013,3017,3030-3031,3052,3071,3077,3128,3168,3211,3221,3260-3261,3268-3269,3283,3300-3301,3306,3322-3325,3333,3351,3367,3369-3372,3389-3390,3404,3476,3493,3517,3527,3546,3551,3580,3659,3689-3690,3703,3737,3766,3784,3800-3801,3809,3814,3826-3828,3851,3869,3871,3878,3880,3889,3905,3914,3918,3920,3945,3971,3986,3995,3998,4000-4006,4045,4111,4125-4126,4129,4224,4242,4279,4321,4343,4443-4446,4449,4550,4567,4662,4848,4899-4900,4998,5000-5004,5009,5030,5033,5050-5051,5054,5060-5061,5080,5087,5100-5102,5120,5190,5200,5214,5221-5222,5225-5226,5269,5280,5298,5357,5405,5414,5431-5432,5440,5500,5510,5544,5550,5555,5560,5566,5631,5633,5666,5678-5679,5718,5730,5800-5802,5810-5811,5815,5822,5825,5850,5859,5862,5877,5900-5904,5906-5907,5910-5911,5915,5922,5925,5950,5952,5959-5963,5987-5989,5998-6007,6009,6025,6059,6100-6101,6106,6112,6123,6129,6156,6346,6389,6502,6510,6543,6547,6565-6567,6580,6646,6666-6669,6689,6692,6699,6779,6788-6789,6792,6839,6881,6901,6969,7000-7002,7004,7007,7019,7025,7070,7100,7103,7106,7200-7201,7402,7435,7443,7496,7512,7625,7627,7676,7741,7777-7778,7800,7911,7920-7921,7937-7938,7999-8002,8007-8011,8021-8022,8031,8042,8045,8080-8090,8093,8099-8100,8180-8181,8192-8194,8200,8222,8254,8290-8292,8300,8333,8383,8400,8402,8443,8500,8600,8649,8651-8652,8654,8701,8800,8873,8888,8899,8994,9000-9003,9009-9011,9040,9050,9071,9080-9081,9090-9091,9099-9103,9110-9111,9200,9207,9220,9290,9415,9418,9485,9500,9502-9503,9535,9575,9593-9595,9618,9666,9876-9878,9898,9900,9917,9929,9943-9944,9968,9990-10004,10009-10010,10012,10024-10025,10082,10180,10215,10243,10566,10616-10617,10621,10626,10628-10629,10778,11110-11111,11967,12000,12174,12265,12345,13456,13722,13782-13783,14000,14238,14441-14442,15000,15002-15004,15660,15742,16000-16001,16012,16016,16018,16080,16113,16992-16993,17877,17988,18040,18101,18988,19101,19283,19315,19350,19780,19801,19842,20000,20005,20031,20221-20222,20828,21571,22939,23502,24444,24800,25734-25735,26214,27000,27352-27353,27355-27356,27715,28201,30000,30718,30951,31038,31337,32768-32785,33354,33899,34571-34573,35500,38292,40193,40911,41511,42510,44176,44442-44443,44501,45100,48080,49152-49161,49163,49165,49167,49175-49176,49400,49999-50003,50006,50300,50389,50500,50636,50800,51103,51493,52673,52822,52848,52869,54045,54328,55055-55056,55555,55600,56737-56738,57294,57797,58080,60020,60443,61532,61900,62078,63331,64623,64680,65000,65129,65389"/>
<verbose level="0"/>
<debugging level="0"/>
<hosthint><status state="up" reason="unknown-response" reason_ttl="0"/>
<address addr="45.33.32.156" addrtype="ipv4"/>
<hostnames>
<hostname name="scanme.nmap.org" type="user"/>
</hostnames>
</hosthint>
<host starttime="1707768285" endtime="1707768354"><status state="up" reason="syn-ack" reason_ttl="0"/>
<address addr="45.33.32.156" addrtype="ipv4"/>
<hostnames>
<hostname name="scanme.nmap.org" type="user"/>
<hostname name="scanme.nmap.org" type="PTR"/>
</hostnames>
<ports><extraports state="closed" count="995">
<extrareasons reason="conn-refused" count="995" proto="tcp" ports="1,3-4,6-7,9,13,17,19-21,23-26,30,32-33,37,42-43,49,70,79,81-85,88-90,99-100,106,109-111,113,119,125,135,139,143-144,146,161,163,179,199,211-212,222,254-256,259,264,280,301,306,311,340,366,389,406-407,416-417,425,427,443-445,458,464-465,481,497,500,512-515,524,541,543-545,548,554-555,563,587,593,616-617,625,631,636,646,648,666-668,683,687,691,700,705,711,714,720,722,726,749,765,777,783,787,800-801,808,843,873,880,888,898,900-903,911-912,981,987,990,992-993,995,999-1002,1007,1009-1011,1021-1100,1102,1104-1108,1110-1114,1117,1119,1121-1124,1126,1130-1132,1137-1138,1141,1145,1147-1149,1151-1152,1154,1163-1166,1169,1174-1175,1183,1185-1187,1192,1198-1199,1201,1213,1216-1218,1233-1234,1236,1244,1247-1248,1259,1271-1272,1277,1287,1296,1300-1301,1309-1311,1322,1328,1334,1352,1417,1433-1434,1443,1455,1461,1494,1500-1501,1503,1521,1524,1533,1556,1580,1583,1594,1600,1641,1658,1666,1687-1688,1700,1717-1721,1723,1755,1761,1782-1783,1801,1805,1812,1839-1840,1862-1864,1875,1900,1914,1935,1947,1971-1972,1974,1984,1998-2010,2013,2020-2022,2030,2033-2035,2038,2040-2043,2045-2049,2065,2068,2099-2100,2103,2105-2107,2111,2119,2121,2126,2135,2144,2160-2161,2170,2179,2190-2191,2196,2200,2222,2251,2260,2288,2301,2323,2366,2381-2383,2393-2394,2399,2401,2492,2500,2522,2525,2557,2601-2602,2604-2605,2607-2608,2638,2701-2702,2710,2717-2718,2725,2800,2809,2811,2869,2875,2909-2910,2920,2967-2968,2998,3000-3001,3003,3005-3007,3011,3013,3017,3030-3031,3052,3071,3077,3128,3168,3211,3221,3260-3261,3268-3269,3283,3300-3301,3306,3322-3325,3333,3351,3367,3369-3372,3389-3390,3404,3476,3493,3517,3527,3546,3551,3580,3659,3689-3690,3703,3737,3766,3784,3800-3801,3809,3814,3826-3828,3851,3869,3871,3878,3880,3889,3905,3914,3918,3920,3945,3971,3986,3995,3998,4000-4006,4045,4111,4125-4126,4129,4224,4242,4279,4321,4343,4443-4446,4449,4550,4567,4662,4848,4899-4900,4998,5000-5004,5009,5030,5033,5050-5051,5054,5060-5061,5080,5087,5100-5102,5120,5190,5200,5214,5221-5222,5225-5226,5269,5280,5298,5357,5405,5414,5431-5432,5440,5500,5510,5544,5550,5555,5560,5566,5631,5633,5666,5678-5679,5718,5730,5800-5802,5810-5811,5815,5822,5825,5850,5859,5862,5877,5900-5904,5906-5907,5910-5911,5915,5922,5925,5950,5952,5959-5963,5987-5989,5998-6007,6009,6025,6059,6100-6101,6106,6112,6123,6129,6156,6346,6389,6502,6510,6543,6547,6565-6567,6580,6646,6666-6669,6689,6692,6699,6779,6788-6789,6792,6839,6881,6901,6969,7000-7002,7004,7007,7019,7025,7070,7100,7103,7106,7200-7201,7402,7435,7443,7496,7512,7625,7627,7676,7741,7777-7778,7800,7911,7920-7921,7937-7938,7999-8002,8007-8011,8021-8022,8031,8042,8045,8080-8090,8093,8099-8100,8180-8181,8192-8194,8200,8222,8254,8290-8292,8300,8333,8383,8400,8402,8443,8500,8600,8649,8651-8652,8654,8701,8800,8873,8888,8899,8994,9000-9003,9009-9011,9040,9050,9071,9080-9081,9090-9091,9099-9103,9110-9111,9200,9207,9220,9290,9415,9418,9485,9500,9502-9503,9535,9575,9593-9595,9618,9666,9876-9878,9898,9900,9917,9943-9944,9968,9990-10004,10009-10010,10012,10024-10025,10082,10180,10215,10243,10566,10616-10617,10621,10626,10628-10629,10778,11110-11111,11967,12000,12174,12265,12345,13456,13722,13782-13783,14000,14238,14441-14442,15000,15002-15004,15660,15742,16000-16001,16012,16016,16018,16080,16113,16992-16993,17877,17988,18040,18101,18988,19101,19283,19315,19350,19780,19801,19842,20000,20005,20031,20221-20222,20828,21571,22939,23502,24444,24800,25734-25735,26214,27000,27352-27353,27355-27356,27715,28201,30000,30718,30951,31038,31337,32768-32785,33354,33899,34571-34573,35500,38292,40193,40911,41511,42510,44176,44442-44443,44501,45100,48080,49152-49161,49163,49165,49167,49175-49176,49400,49999-50003,50006,50300,50389,50500,50636,50800,51103,51493,52673,52822,52848,52869,54045,54328,55055-55056,55555,55600,56737-56738,57294,57797,58080,60020,60443,61532,61900,62078,63331,64623,64680,65000,65129,65389"/>
</extraports>
<port protocol="tcp" portid="22"><state state="open" reason="syn-ack" reason_ttl="0"/><service name="ssh" method="table" conf="3"/></port>
<port protocol="tcp" portid="53"><state state="open" reason="syn-ack" reason_ttl="0"/><service name="domain" method="table" conf="3"/></port>
<port protocol="tcp" portid="80"><state state="open" reason="syn-ack" reason_ttl="0"/><service name="http" method="table" conf="3"/></port>
<port protocol="tcp" portid="9929"><state state="open" reason="syn-ack" reason_ttl="0"/><service name="nping-echo" method="table" conf="3"/></port>
<port protocol="tcp" portid="31337"><state state="open" reason="syn-ack" reason_ttl="0"/><service name="Elite" method="table" conf="3"/></port>
</ports>
<times srtt="183762" rttvar="694" to="186538"/>
</host>
<runstats><finished time="1707768354" timestr="Mon Feb 12 23:05:54 2024" summary="Nmap done at Mon Feb 12 23:05:54 2024; 1 IP address (1 host up) scanned in 75.21 seconds" elapsed="75.21" exit="success"/><hosts up="1" down="0" total="1"/>
</runstats>
</nmaprun>
```

Nmap вывод результата

Несколько форматов:

> nmap -oA output scanme.nmap.org

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE nmaprun>
<?xml-stylesheet href="file:///usr/bin/../share/nmap/nmap.xsl" type="text/xsl"?>
<!-- Nmap 7.40 scan initiated Wed Jul 22 08:17:51 2020 as: nmap -oX scanme.nmap.org -&#45;top-ports 10 -->
<nmaprun scanner="nmap" args="nmap -oX scanme.nmap.org -&#45;top-ports 10" start="1595405871" startstr="Wed Jul 22 08:17:51 2020" versio
n="7.40" xmloutputversion="1.04">
<scaninfo type="syn" protocol="tcp" numservices="10" services="21-23,25,80,110,139,443,445,3389"/>
<verbose level="0"/>
<debugging level="0"/>
<runstats><finished time="1595405871" timestr="Wed Jul 22 08:17:51 2020" elapsed="0.03" summary="Nmap done at Wed Jul 22 08:17:51 2020;
0 IP addresses (0 hosts up) scanned in 0.03 seconds" exit="success"/><hosts up="0" down="0" total="0"/>
</runstats>
</nmaprun>
```

Nmap Scripting Engine

Nmap Scripting Engine

Nmap Scripting Engine (NSE) - это мощный инструмент, который вы можете использовать для написания сценариев и автоматизации многочисленных сетевых функций.

Nmap Scripting Engine

NSE — это встроенный Lua-движок, который превращает Nmap в:

- 🔎 инструмент глубокой разведки (enumeration)
- 🛡️ сканер уязвимостей
- 🔐 инструмент проверки аутентификации
- 🧠 систему автоматизации этапов атаки
- ⚙️ платформу для написания собственных security-скриптов

Почему NSE делает nmap принципиально другим?

Обычный Nmap	Nmap + NSE
Открыт порт 80	Apache 2.2.14
Открыт порт 443	Поддержка слабых SSL
Открыт 445	Список пользователей, шары, домен
Открыт 21	Проверка анонимного входа

Фактически NSE позволяет:

✔ выполнять активные проверки

✔ взаимодействовать с сервисами

✔ писать собственные скрипты

✔ автоматизировать этап Recon → Exploit

Под капотом

- Язык: Lua
- 600 встроенных скриптов
- Категории: safe, vuln, auth, brute, intrusive, exploit
- Параллельное выполнение

Nmap Scripting Engine

```
http-avaya-ipoffice-users.nse
http-awstatstotals-exec.nse
http-axis2-dir-traversal.nse
http-backup-finder.nse
http-barracuda-dir-traversal.nse
http-brute.nse
http-cakephp-version.nse
http-chrono.nse
http-cisco-anyconnect.nse
http-coldfusion-subzero.nse
http-comments-displayer.nse
http-config-backup.nse
http-cors.nse
http-cross-domain-policy.nse
http-csrf.nse
http-date.nse
http-default-accounts.nse
http-devframework.nse
http-dlink-backdoor.nse
http-dombased-xss.nse
http-domino-enum-passwords.nse
http-drupal-enum.nse
http-drupal-enum-users.nse
http-enum.nse
http-errors.nse
http-exif-spider.nse
http-favicon.nse
http-feed.nse
http-fetch.nse
http-fileupload-exploiter.nse
http-form-brute.nse
http-form-fuzzer.nse
http-frontpage-login.nse
ms-sql-empty-password.nse
ms-sql-hasdbaccess.nse
ms-sql-info.nse
ms-sql-ntlm-info.nse
ms-sql-query.nse
ms-sql-tables.nse
ms-sql-xp-cmdshell.nse
mtrace.nse
murmur-version.nse
mysql-audit.nse
mysql-brute.nse
mysql-databases.nse
mysql-dump-hashes.nse
mysql-empty-password.nse
mysql-enum.nse
mysql-info.nse
mysql-query.nse
mysql-users.nse
mysql-variables.nse
mysql-vuln-cve2012-2122.nse
nat-pmp-info.nse
nat-pmp-mapport.nse
nbstat.nse
ncp-enum-users.nse
ncp-serverinfo.nse
ndmp-fs-info.nse
ndmp-version.nse
nessus-brute.nse
nessus-xmlrpc-brute.nse
netbus-auth-bypass.nse
netbus-brute.nse
netbus-info.nse
netbus-version.nse
telnet-ntlm-info.nse
tftp-enum.nse
tls-nextprotoneg.nse
tn3270-screen.nse
tor-consensus-checker.nse
traceroute-geolocation.nse
tso-brute.nse
tso-enum.nse
unittest.nse
unusual-port.nse
upnp-info.nse
url-snarf.nse
ventrilo-info.nse
versant-info.nse
vmauthd-brute.nse
vnc-brute.nse
vnc-info.nse
vnc-title.nse
voldemort-info.nse
vtam-enum.nse
vuze-dht-info.nse
wdb-version.nse
weblogic-t3-info.nse
whois-domain.nse
whois-ip.nse
wsdd-discover.nse
x11-access.nse
xdmcp-discover.nse
xmlrpc-methods.nse
xmpp-brute.nse
xmpp-info.nse
```

ls /usr/share/nmap/scripts

Nmap Scripting Engine

```lua
portrule = function(host, port)
  return port.protocol == "tcp" and port.state == "open"
end

action = function(host, port)
  return ("\nHello, port %d!\nHave a nice
day."):format(port.number)
end
```

Пример nse-скрипта (lua)

Проверка заголовка Server

```
description = [[
Retrieves HTTP Server header from web service.
]]

author = "Pavel"
license = "Same as Nmap"
categories = {"discovery", "safe"}

local http = require "http"

portrule = function(host, port)
  return port.number == 80 or port.number == 8080
end

action = function(host, port)
  local response = http.get(host, port, "/")

  if response and response.header and response.header["server"] then
    return "Server header: " .. response.header["server"]
  else
    return "No Server header found"
  end
end
```

Nmap Scripting Engine

```
nmap -iL input_ips.txt –script=vuln
```

```
nmap -p 80 --script ./http-server-check.nse scanme.nmap.org
```

Nmap Scripting Engine

```
nmap -p 21 --script ftp-brute target.local
```

```
nmap -p 22 --script ssh-brute target.local
```

```
nmap -p 80 --script http-brute target.local
```

Nmap Scanning Pipeline

```
+----------------------------+
|  2) Port Scan              |
|  nmap -sS/-sT  -p-         |
|  (быстро: top-ports)       |
+-------------+--------------+
              |
              v
+----------------------------+
|  3) Service/Version Detect |
|  nmap -sV                  |
+-------------+--------------+
              |
              v
+----------------------------+
|  4) NSE: Discovery / Enum  |
|  --script "default,discovery,
|           safe,enum"       |
|  (HTTP/DNS/SMB/SNMP/...)   |
+-------------+--------------+
              |
              v
+----------------------------+
|  5) NSE: Vuln Checks        |
|  --script "vuln"            |
|  (CVE / misconfig / crypto) |
+-------------+--------------+
              |
              v
+----------------------------+
|  6) NSE: Auth / Brute (lab)|
|  --script "auth,brute"     |
|  (SSH/FTP/HTTP/SMB/...)    |
+-------------+--------------+
```

Naabu

Сканирование AS

```
echo AS14421 | naabu -p 80,443
```

```
216.101.17.249:80
216.101.17.249:443
216.101.17.248:443
216.101.17.252:443
216.101.17.251:80
216.101.17.251:443
216.101.17.250:443
216.101.17.250:80
```

Вывод в JSON

naabu -host 104.16.99.52 -json

{"ip":"104.16.99.52","port":443}

{"ip":"104.16.99.52","port":80}

Naabu & Nmap

```
echo hackerone.com | naabu -nmap-cli 'nmap -sV -oX nmap-output'
                 __
  ___  ___  ___ _/ /  __ __
 / _ \/ _ \/ _ \/ _ \/ // /
/_//_/\_,_/\_,_/_.__/\_,_/ v2.0.0

    projectdiscovery.io

[WRN] Use with caution. You are responsible for your actions
[WRN] Developers assume no liability and are not responsible for any misuse or damage.
[INF] Running TCP/ICMP/SYN scan with root privileges
[INF] Found 4 ports on host hackerone.com (104.16.99.52)

hackerone.com:443
hackerone.com:80
hackerone.com:8443
hackerone.com:8080

[INF] Running nmap command: nmap -sV -p 80,8443,8080,443 104.16.99.52

Starting Nmap 7.01 ( https://nmap.org ) at 2020-09-23 05:02 UTC
Nmap scan report for 104.16.99.52
Host is up (0.0021s latency).
PORT     STATE SERVICE       VERSION
80/tcp   open  http          cloudflare
443/tcp  open  ssl/https     cloudflare
8080/tcp open  http-proxy    cloudflare
8443/tcp open  ssl/https-alt cloudflare
```

Naabu Fast Scan, Verify, Nmap Services

```
naabu -list subdomains.txt -verify -ec -rate 9000 -retries 1 -p 0-65535
-warm-up-time 0 -c 50 -nmap-cli "nmap -sV -oG nmap-naabu-out" -silent -o
naabu-full.txt
```

Naabu & Nuclei

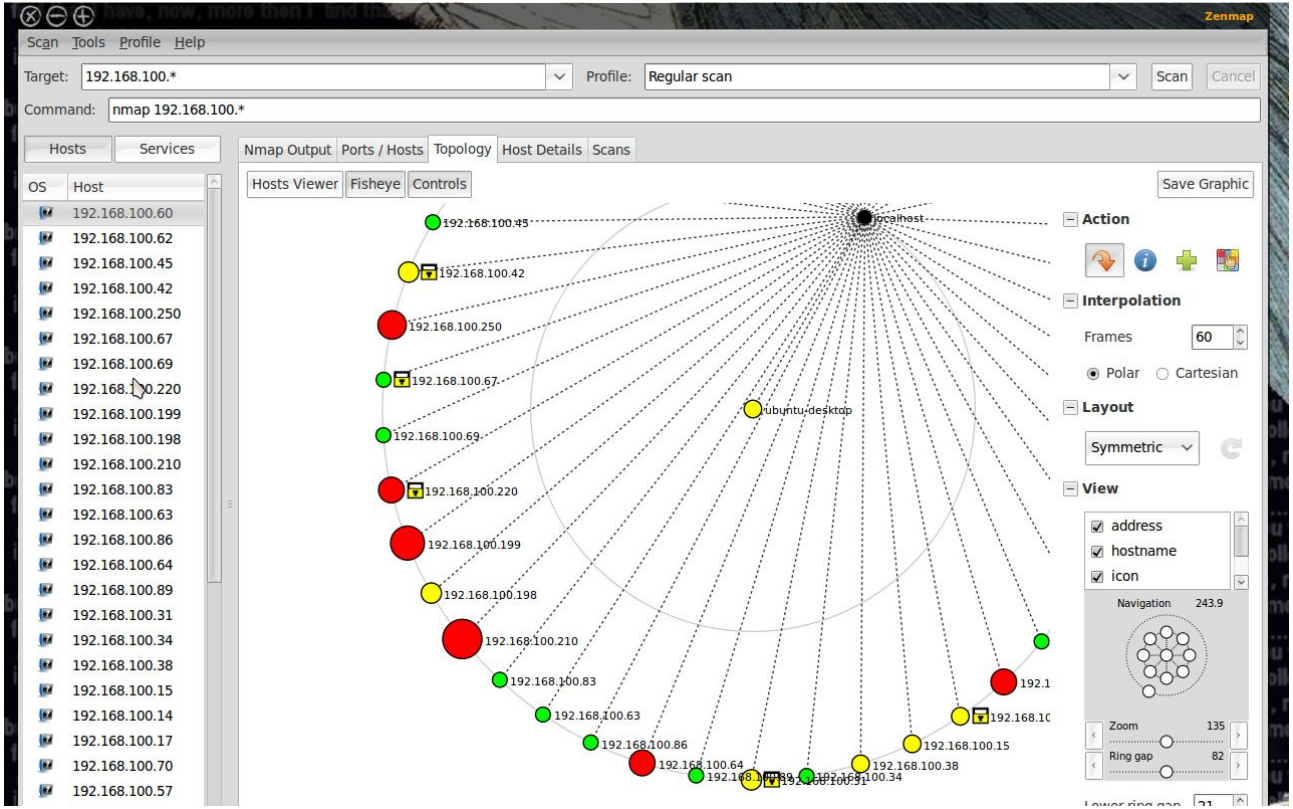
```
naabu -list subdomains.txt  | nuclei -t /path/to/your-template.yaml
```

Zenmap

Zenmap

Zenmap - это графический пользовательский интерфейс для Nmap. Это бесплатное программное обеспечение с открытым исходным кодом, которое поможет вам начать работу с Nmap.

Zenmap


Zenmap
Scan Tools Profile Help
Target: 192.168.100.*
Profile: Regular scan
Scan
Cancel
Command: nmap 192.168.100.*
Hosts
Services
Nmap Output
Ports / Hosts
Topology
Host Details
Scans
OS
Host
192.168.100.60
192.168.100.62
192.168.100.45
192.168.100.42
192.168.100.250
192.168.100.67
192.168.100.69
192.168.100.220
192.168.100.199
192.168.100.198
192.168.100.210
192.168.100.83
192.168.100.63
192.168.100.86
192.168.100.64
192.168.100.89
192.168.100.31
192.168.100.34
192.168.100.38
192.168.100.15
192.168.100.14
192.168.100.17
192.168.100.70
192.168.100.57
Hosts Viewer
Fisheye
Controls
Save Graphic
localhost
ubuntu-desktop
Action
Interpolation
Frames
60
Polar
Cartesian
Layout
Symmetric
View
address
hostname
icon
Navigation
243.9
Zoom
135
Ring gap
82